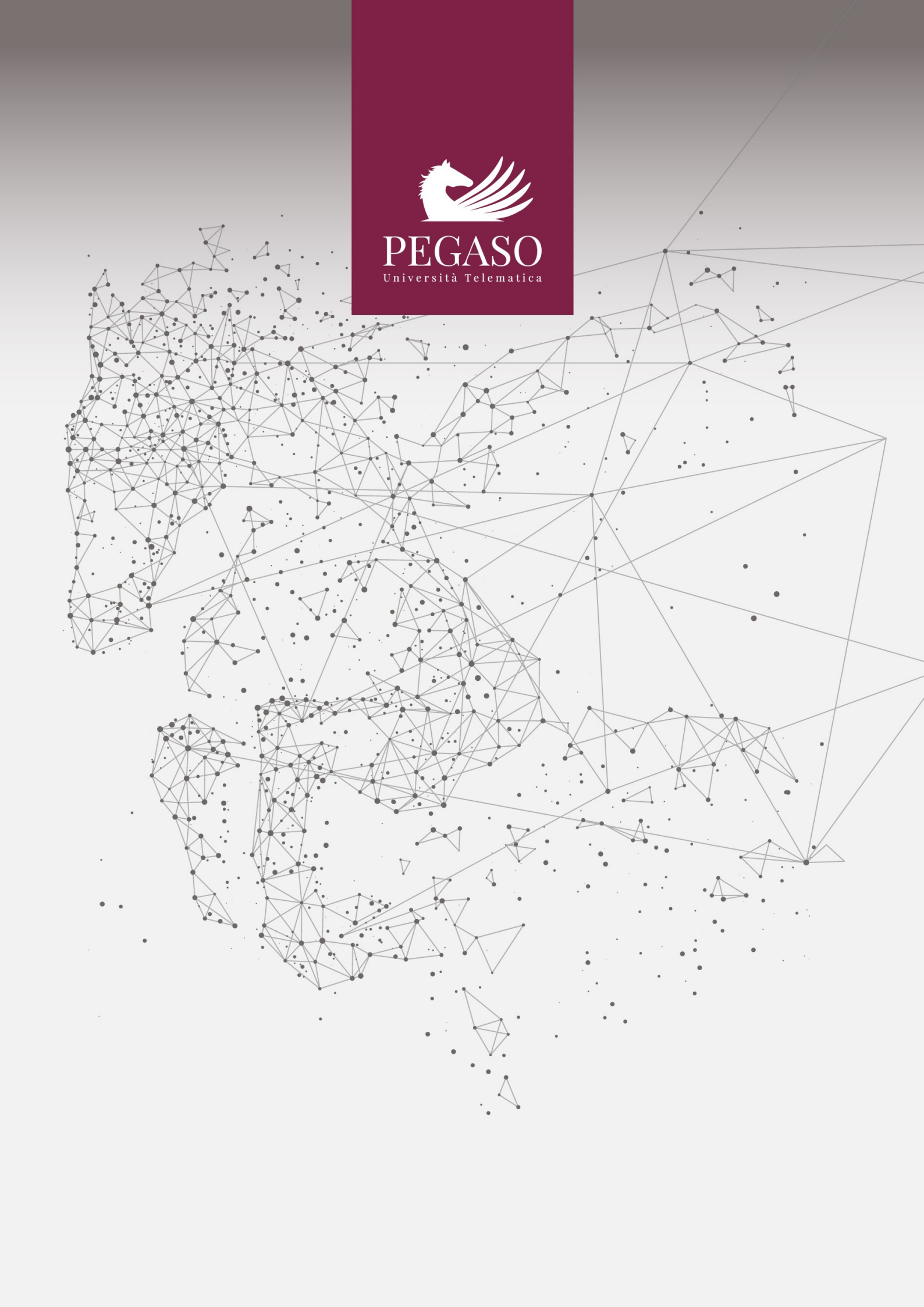

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 PGP: INTRODUZIONE 3
2 PGP: AUTENTICAZIONE 5
3 PGP: SEGRETEZZA 7
4 PGP: COMPRESSIONE, COMPATIBILITÀ E FRAMMENTAZIONE 9
BIBLIOGRAFIA 11

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 PGP: introduzione

La posta elettronica è sicuramente l'applicazione di rete più diffusa, essa viene utilizzata in qualsiasi architettura e piattaforma, indipendentemente dal sistema operativo. Esistono fondamentalmente due standard per la posta elettronica:

- **PGP (Pretty Good Privacy)**
- **S/MIME (Secure/Multipurpose Internet Mail Extension)**

In questa lezione cominciamo ad introdurre le funzionalità di PGP.

PGP è un servizio di segretezza e autenticazione utilizzato per la posta elettronica evoluto nello standard *OpenPGP (RFC4880)*. PGP è dovuto fondamentalmente a Phil Zimmermann ed è disponibile per molteplici piattaforme

PGP è basato su vari algoritmi crittografici sicuri quali:

- RSA, DSS e Diffie-Hellman per ciò che concerne la crittografia pubblica
- CAST-128, IDEA e 3DES per la crittografia simmetrica
- SHA-1 per la codifica hash

Il PGP comprende fondamentalmente 5 servizi:

- *Autenticazione (firma digitale)*: basata sulla codifica hash SHA-1 e sulla cifratura pubblica (DSS o RSA)
- *Segretezza (crittografia)*: basata su cifratura simmetrica del messaggio (CAST-128 o IDEA o 3DES) con una chiave di sessione che viene cifrata con crittografia a chiave pubblica (Diffie-Hellmann o RSA)
- *Compressione*: basata sull'algoritmo ZIP
- *Compatibilità con la posta elettronica*: basata sulla conversione ASCII radix-64
- *Segmentazione (riassemblaggio)*: per gestire le dimensioni del messaggio

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Nei prossimi paragrafi saranno analizzati questi 5 servizi, intanto introduciamo delle notazioni che verranno utilizzate da qui in avanti:

Notazioni	
K_s	chiave di sessione per la crittografia simmetrica
PR_a/PU_a	coppia chiave privata/pubblica per la crittografia pubblica
EP/DP	crittografia/decrittografia a chiave pubblica
EC/DC =	crittografia/decrittografia simmetrica
H	funzione hash
||	concatenamento
Z	compressione ZIP
R64	conversione al formato ASCII radix-64

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

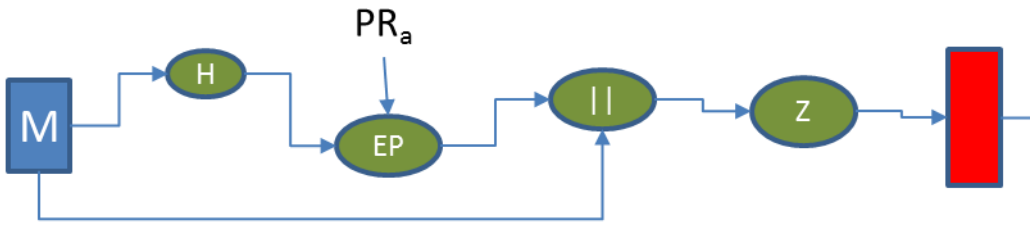
2 PGP: autenticazione

Nel PGP, l'autenticazione viene garantita tramite la firma digitale

- Si usa SHA-1 come funzione hash (genera un hash a 160 bit)
- Si usa RSA (oppure DSS) come funzione di crittografia a chiave pubblica

Come si vede dallo schema rappresentato nella figura sottostante, tale funzione, pur garantendo sulla provenienza del messaggio, non ne garantisce la segretezza. Vediamo adesso i vari passi.

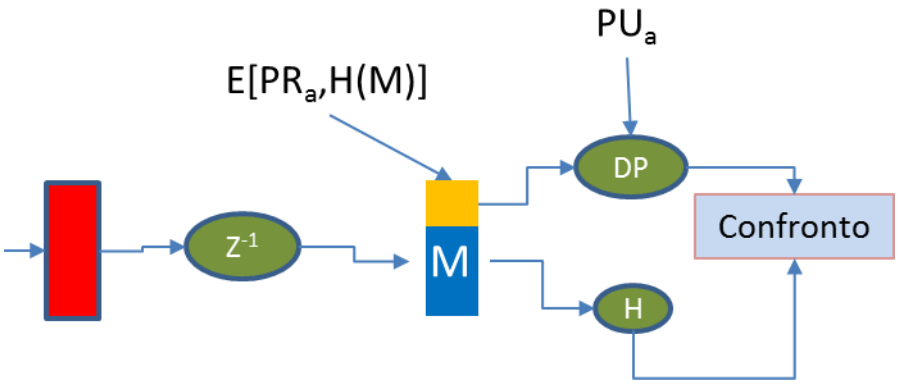
Il mittente vuole inviare il messaggio M, ne genera un hash con l'algoritmo SHA-1 e lo cifra (lo firma) mediante la cifratura asimmetrica (e.g. RSA) usando la propria chiave privata PR_a. Il risultato di tale cifratura viene concatenato con il messaggio M e compresso (ZIP) prima di essere inviato nel canale (blocco in rosso).



Il destinatario del messaggio esegue, prima di tutto, l'operazione di decompressione (UNZIP), ottenendo il concatenamento tra il messaggio in chiaro M e il cifrato con la chiave privata del mittente (PR_a) dell'hash del messaggio stesso (vedi figura sottostante). Il destinatario utilizzando la chiave pubblica del mittente PU_a può ottenere l'hash H(M) e confrontarlo con il calcolo dell'hash sul messaggio ricevuto che lui stesso effettua. Se il confronto dà esito positivo, allora il destinatario è sicuro che quello è il messaggio inviato dal mittente. Nuovamente si capisce bene che la segretezza del messaggio M non è in questo caso garantita da questo tipo di servizio.

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

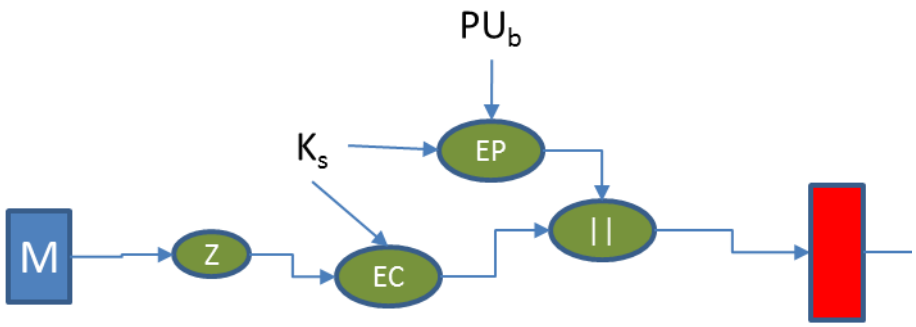
3 PGP: segretezza

Un altro servizio fondamentale offerto da PGP è la segretezza garantita tramite la crittografia simmetrica (CAST-128, IDEA o 3DES); la modalità di cifratura utilizzata è CFB (Cipher Feedback) a 64 bit.

La chiave di crittografia simmetrica K_s viene utilizzata una sola volta (chiave monouso) e generata sotto forma di numero casuale a 128 bit. Tale chiave viene distribuita tra le due entità che vogliono comunicare mediante la cifratura pubblica RSA.

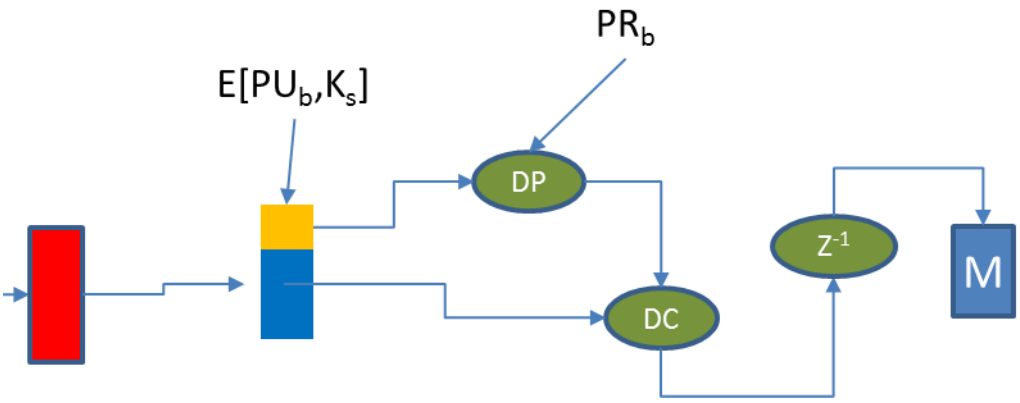
In questo caso, solo il destinatario è in grado di recuperare la chiave di sessione K_s (segretezza) ma non c'è un'autenticazione del mittente. Vediamo, anche in questa situazione, i vari passi (figura sottostante).

Il mittente che vuole inviare il messaggio M lo comprime (ZIP) e poi lo cifra in maniera simmetrica (e.g 3DES) mediante la chiave di sessione K_s; tale chiave di sessione, viene poi a sua volta cifrata con RSA usando la chiave pubblica del destinatario PU_b e concatenata con il messaggio compresso cifrato prima di essere inviata al destinatario.



Il destinatario (vedi figura successiva) riceve appunto il concatenamento del messaggio cifrato e della chiave di sessione cifrata; utilizza la sua chiave PR_b (di cui solo lui dispone e perciò la segretezza è garantita) per ottenere la chiave di sessione K_s, decifrare il messaggio e decomprimerlo.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



PGP offre la possibilità di applicare ad un messaggio entrambi i servizi di *autenticazione* e *segretezza* così da garantire entrambe:

– Prima si effettua la cifratura del messaggio con la chiave privata del mittente (*autenticazione*)

– Poi si cifra il tutto con la chiave di sessione K_s (*segretezza*) che poi viene a sua volta cifrata con la chiave pubblica del destinatario ed inviata

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

4 PGP: compressione, compatibilità e frammentazione

PGP esegue anche la **compressione Z (ZIP)** del messaggio al fine di ridurne le dimensioni. È importante notare che tale compressione avviene, nel caso di servizio di autenticazione e segretezza, dopo aver applicato la firma ma prima della crittografia simmetrica con la chiave di sessione K_s. La compressione agisce quindi sul messaggio in chiaro (ciò avviene peraltro anche nel caso del solo servizio di segretezza).

- La firma viene generata prima della compressione in quanto è preferibile firmare un messaggio non compresso così da poter memorizzare solo il messaggio non compresso per operazioni eventuali di verifica
- La crittografia del messaggio viene applicata dopo la compressione per rafforzare la sicurezza crittografica in quanto il messaggio compresso presenta una minore ridondanza rispetto al testo in chiaro, così da rendere l'analisi crittografica più difficile.

Il PGP deve anche garantire un servizio di **compatibilità** con molti sistemi di posta elettronica che consentono di impiegare solo blocchi costituiti da testo in formato ASCII; a tale scopo, PGP fornisce un servizio di conversione:

– gruppi di 8 bit sono convertiti in caratteri ASCII stampabili

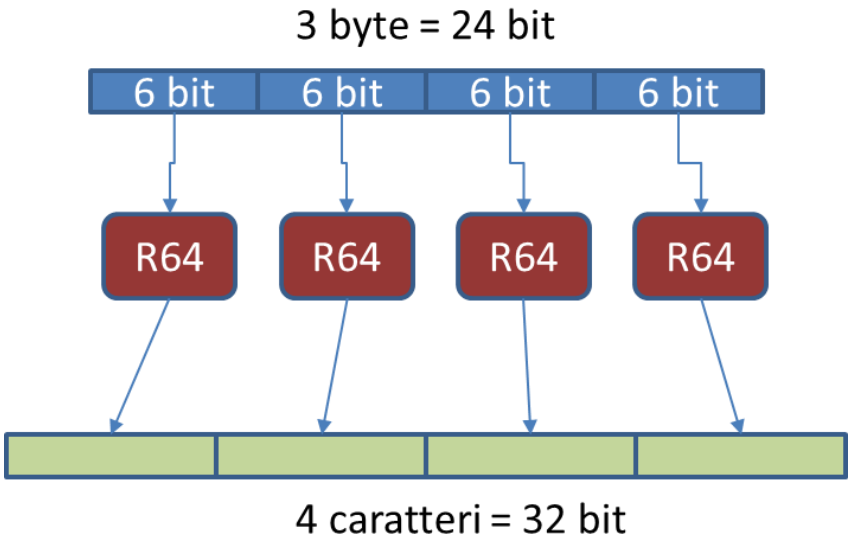
– si usa la conversione *radix-64*

– un gruppo di 3 byte viene mappato in 4 caratteri ASCII: c'è un'espansione del 33%.

La conversione *radix-64* esegue sostanzialmente la mappatura visualizzata nella figura sottostante:

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Ogni gruppo di 3 byte (24 bit), viene suddiviso in 4 sottogruppi di 6 bit ciascuno. Ogni sottogruppo di 6 bit (2^6=64) viene mappato sulla base della conversione *radix-64* in uno di 64 caratteri ASCII (costituito ognuno da 8 bit) rappresentati in ordine da:

- 26 lettere maiuscole (A, B,C,…..X, Y, Z)
- 26 lettere minuscole (a, b, c,……,x, y, z)
- 10 numeri (0-9)
- 2 segni: - e /
- = serve come carattere di riempimento

Infine il PGP, poiché molti sistemi di posta elettronica pongono limiti sulla lunghezza massima dei messaggi (p.e. 50.000 ottetti), prevede un servizio in cui ogni messaggio deve essere suddiviso (**frammentazione**) in più segmenti che devono essere inviati separatamente. La chiave di sessione e la firma compariranno una sola volta all'inizio del primo segmento; all'estremità ricevente PGP deve eliminare tutte le intestazioni e riassemblare l'intero blocco.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: *Capitolo 15.*

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).